



CyberEdu

La sécurité par l'enseignement supérieur des NTIC

Sensibilisation et initiation à la cybersécurité

Module 4 : La gestion de la cybersécurité au sein d'une organisation

Ce document pédagogique a été rédigé par un consortium regroupant des enseignants-chercheurs et des professionnels du secteur de la cybersécurité.



Il est mis à disposition par l'ANSSI sous licence Creative Commons Attribution 3.0 France.



CyberEdu

La sécurité par l'enseignement supérieur des NTIC

Plan du module

- 1. Intégrer la sécurité au sein d'une organisation**
- 2. Intégrer la sécurité dans les projets**
- 3. Difficultés liées à la prise en compte de la sécurité**
- 4. Métiers liés à la cybersécurité**

1. Intégrer de la sécurité au sein d'une organisation

- a) Préambule
- b) Panorama des normes ISO 2700x
- c) Système de Management de la Sécurité de l'Information (27001)
- d) Code de bonnes pratiques pour le management de la sécurité de l'information (27002)
- e) Gestion des risques (27005)
- f) Classification des informations
- g) Gestion des ressources humaines

1. Intégrer la sécurité au sein d'une organisation

a. Préambule

- Les mesures de sécurité à mettre en place dépendent de l'activité, de l'organisation et de la réglementation et des contraintes de son écosystème.
- Afin d'évaluer le niveau de sécurité attendue, les questions suivantes peuvent être posées :
 - Qu'est ce que je veux protéger ?
 - De quoi je veux me protéger ?
 - A quel type de risques mon organisation est exposée ?
 - Qu'est ce que je redoute ?
 - Quelles sont les normes qui s'appliquent à mon organisation ?
- L'organisation peut s'inspirer de la famille de norme internationale ISO 27000 et des guides nationaux (ANSSI, CLUSIF, etc.), voire des politiques de sécurité en usage dans l'État (PSSIE, RGS, etc.) pour mettre en place la sécurité.

1. Intégrer la sécurité au sein d'une organisation

b. Panorama des normes ISO 27K

- Ensemble de normes internationales de sécurité de l'information, destinées à protéger l'information. Elles découlent d'une recherche de consensus commun sur le domaine.
- Néanmoins la conformité à une norme ne garantit pas formellement un niveau de sécurité. Les normes ne prennent pas en compte l'état de l'art récent et les exigences réglementaires.
- Quelques unes des principales normes incluses dans la série 27000 :

27001

- Systèmes de management de la sécurité de l'information

27002

- Code de bonnes pratiques

27004

- Mesures du management de la sécurité

27005

- Gestion des risques

27035

- Gestion des incidents de sécurité

27037

- Traitement des preuves numériques (*forensics*)

...

- ...

1. Intégrer la sécurité au sein d'une organisation

b. Panorama de normes ISO 2700x

- Dans le cadre de la mise en place de la sécurité au sein d'une organisation :
 - La norme **ISO 27001** permet à une organisation de **mettre en œuvre et d'améliorer le système de management de la sécurité** :
 - Une certification ISO 27001 délivrée par un organisme certificateur accrédité garantit suite à un audit qu'une organisation a bien appliquée les exigences de la norme en matière de sécurité. Cette certification est valable 3 ans, tous les ans un audit de contrôle est effectué.
 - Il peut être exigé à une organisation d'avoir cette certification pour accéder à certains contrats : par exemple un organisme payeur d'aides agricoles européennes.
 - La norme **ISO 27002** définit un ensemble de « **bonnes pratiques** » en matière de sécurité répartie en plusieurs chapitres, l'organisation dispose :
 - d'un référentiel de mise en œuvre ;
 - d'une « check-list » en cas d'audit.
 - La norme **ISO 27005** définit des lignes directrices relatives à la **gestion des risques de sécurité** dans une organisation. Une organisation peut s'appuyer sur ce processus de gestion de risques pour intégrer la sécurité.

1. Intégrer la sécurité au sein d'une organisation

c. Système de Management de la Sécurité de l'Information (27001)

Une démarche calquée sur ISO 9000 (**Plan / Do / Check / Act**).

Phase Plan : Fixer des **objectifs** et des **plans d'actions** :

- Identification des actifs ou des biens ;
- Analyse de risques ;
- Choisir le périmètre du SMSI (Système de Management de la SI) :
 - Quel périmètre ? C'est le domaine d'application du SMSI, son choix est libre, mais il doit être circonscrit, ce sont toutes les activités pour lesquelles l'organisation exige de la confiance.
 - Quelle politique de sécurité ?
 - Quel niveau de sécurité : intégrité, confidentialité, disponibilité de l'information au sein de l'organisation ?



Noter que la norme n'impose pas de niveau minimum de sécurité à atteindre.

Attention : une entreprise peut donc être certifiée ISO 27001 tout en ayant défini un périmètre réduit et une politique de sécurité peu stricte.



1. Intégrer la sécurité au sein d'une organisation

c. *Système de Management de la Sécurité de l'Information (27001)*

- **Phase Do** : mise en œuvre et exploitation des mesures et de la politique
 - Établir un plan de traitement des risques ;
 - Déployer les mesures de sécurité ;
 - Former et sensibiliser les personnels ;
 - Détecter les incidents en continu pour réagir rapidement.
- **Phase Check** : mesurer les résultats issus des actions mises en œuvre
 - Audits internes de conformité et d'efficacité du SMSI (ponctuels et planifiés) ;
 - Réexaminer l'adéquation de la politique SSI avec son environnement ;
 - Suivre l'efficacité des mesures et la conformité du système ;
 - Suivre les risques résiduels (risque qui reste non géré, même lorsque des mesures efficaces de réduction des risques de catastrophe sont en place)
- **Phase Act** :
 - Planifier et suivre les actions correctrices et préventives.

1. Intégrer la sécurité au sein d'une organisation

c. *Système de Management de la Sécurité de l'Information (27001)*

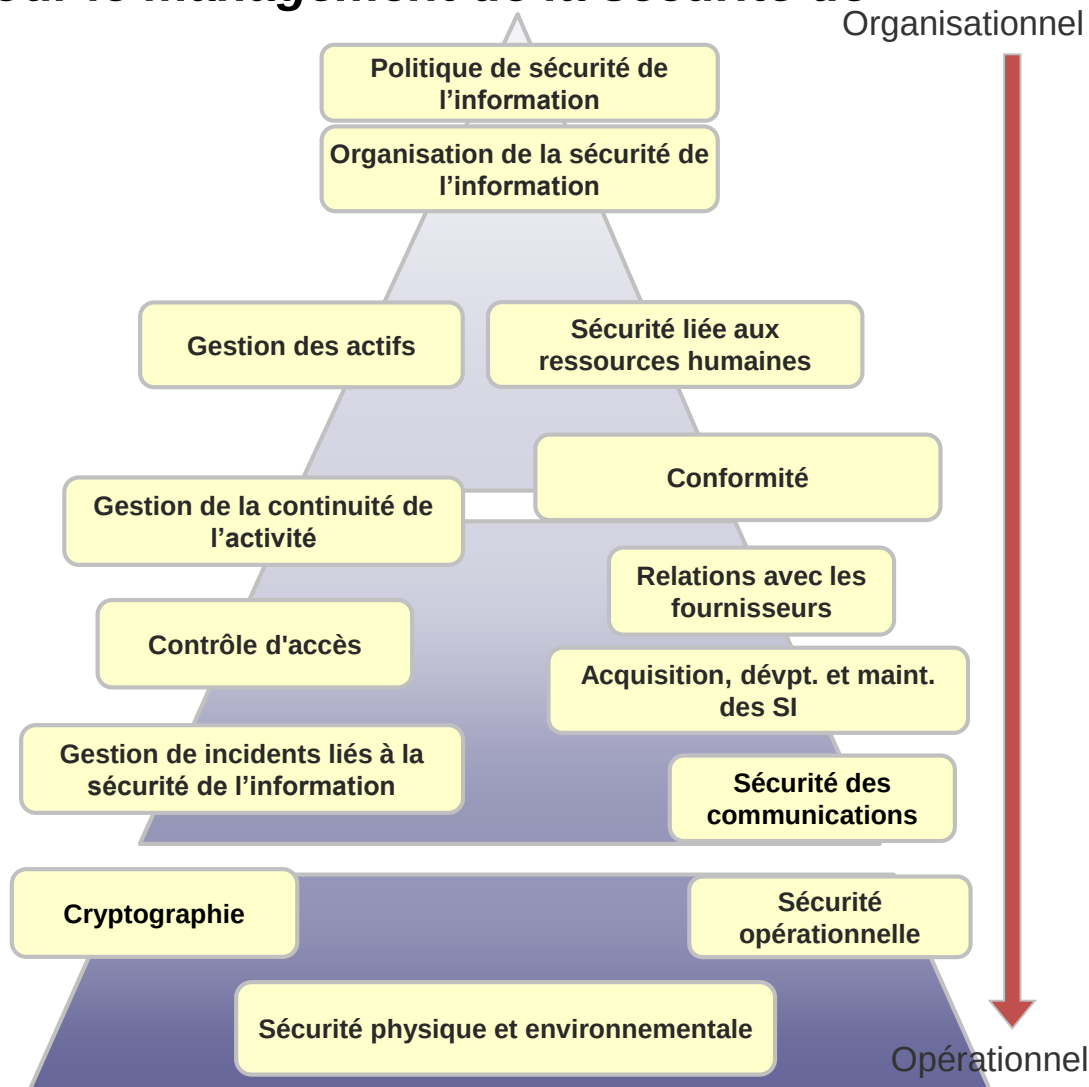
Avantages

- Description détaillée de la **mise en œuvre des objectifs et des mesures de sécurité** ;
- **Audits réguliers** qui permettent le suivi entre les risques initialement identifiés, les mesures prises et les risques nouveaux ou mis à jour. Objectif : mesurer l'**efficacité** des mesures prises ;
- **Sécurité** : une amélioration continue de la sécurité : donc un niveau croissant de sécurité et de maturité en SSI ;
- Meilleure **maîtrise** des différents **risques** ;
- Élimination des mesures de sécurité non utilisées ;
- Amélioration de la **confiance des associés, partenaires & clients** ;
- **Référentiel international** qui facilite les échanges ;
- **Indicateurs** clairs et fiables produisant des éléments de pilotage financier pour les dirigeants.

1. Intégrer la sécurité au sein d'une organisation

d. Code de bonnes pratiques pour le management de la sécurité de l'information (27002)

- La norme ISO/IEC 27002:2013 constitue un code de bonnes pratiques. Elle est composée de 114 mesures de sécurité réparties en 14 chapitres couvrant les domaines organisationnels et techniques ci-contre.
- C'est en adressant l'ensemble de ces domaines que l'on peut avoir une approche globale de la sécurité des S.I.



1. Intégrer la sécurité au sein d'une organisation

d. Code de bonnes pratiques pour le management de la sécurité de l'information (27002)

- Exemples de mesures sur le chapitre « Contrôle d'accès » :
 - L'accès aux fichiers/répertoires doit être restreint conformément aux politiques de contrôle d'accès :
 - Seuls les professeurs autorisés doivent pouvoir accéder à un répertoire contenant les épreuves des futurs examens/concours.
 - Les propriétaires de l'information doivent vérifier les droits d'accès à intervalles réguliers :
 - Le responsable des concours doit contrôler les droits d'accès au répertoire contenant les épreuves des futurs examens/concours pour s'assurer qu'il n'y a pas d'étudiants qui auraient été rajoutés.
- Exemple de mesures sur le chapitre « Sécurité opérationnelle » :
 - L'installation et la configuration de logiciels doivent être encadrés :
 - Seuls les administrateurs doivent pouvoir installer un logiciel sur un poste.
 - Des sauvegardes doivent être régulièrement effectuées et testées :
 - Un espace de sauvegarde des données peut être mis à disposition des utilisateurs.

1. Intégrer la sécurité au sein d'une organisation

e. Gestion des risques (27005)

La norme 27005 présente une démarche :

- Établissement du contexte de l'analyse des risques ;
- Définition de l'appréciation des risques SSI ;
- Choix pour le traitement du risque SSI ;
- Acceptation du risque ;
- Communication et concertation relative aux risques SSI ;
- Surveillance et revue du risque en SSI.

Avantages

- Définit une démarche rationnelle qui a donné lieu à des méthodes qui fonctionnent ;
- Grande souplesse : utilisée en toutes circonstances, surtout lors des changements ;
- Pragmatique et utilisable seule, elle peut aussi bien convenir aux petites organisations.

Limites

- L'organisation doit définir sa propre approche ;
- Méthodes nécessitant souvent de la formation et non adaptables à toutes les situations ;
- Dépendance vis-à-vis de la cartographie du SI : profondeur, étendue etc. ;
- Tendance à l'exhaustivité ;
- Accumulation de mesures techniques sans cohérence d'ensemble.

1. Intégrer la sécurité au sein d'une organisation

Exemple d'analyse des risques

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y
No	Service relevant du SASI	Actifs Essentiels	Critères de sécurité	Evenements redoutés	Actifs support	Vulnérabilités	Menaces	Gravité	Vrais. Fréq.	Criticité brute	Moyens de prévention et/ou de protection existant	Gravité	Vrais. Fréq.	Criticité nette	Catégorie du risque	Décision	Moyens de prévention et/ou d'amélioration	Responsable / Propriétaire	Gravité	Vrais. Fréq.	Criticité résiduelle	Catégorie du risque	Décision	Priorité Risque
R001	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles (perte de disponibilité)	Logiciel XXX	Faillie	Bug, erreur humaine	4	1	4	Mise à jour régulières des versions du logiciel par le fournisseur	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							
R002	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles (perte de disponibilité)	Logiciel XXX	Faillie	Malveillance (exploitation de la faille)	4	1	4	Mise à jour régulières des versions du logiciel par le fournisseur	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							
R003	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles	Logiciel XXX	Montée de version	Procédure de mise à jour non respectée	4	2	7	Mise en place d'un environnement de test et de pré-production afin de tester les nouvelles versions du logiciel XXX	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							
R004	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles	Logiciel XXX	Montée de version	Mise à jour buggée	4	2	7	Mise en place d'un environnement de test et de pré-production afin de tester les nouvelles versions du logiciel XXX	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							
R005	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles	Logiciel XXX	Code non optimisé	dépassement des limites du logiciel	4	3	12	Mise en place d'un environnement de test et de pré-production en volumétrie réelle afin de tester les nouvelles versions du logiciel XXX	4	2	7	Risque à surveiller	4. Accepter	Le risque est accepté							
R006	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles	Serveur d'infrastructure (ESX, Oracle, ...)	Modification du matériel	Procédure de mise à jour matérielle non respectée	4	2	7	Environnement doublé (si panne sur primaire, utilisation du secondaire) Tests dans un environnement de pré-production	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							
R007	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles	Serveur d'infrastructure (ESX, Oracle, ...)	Défaillance matérielle	Panne	4	2	7	Environnement doublé (si panne sur primaire, utilisation du secondaire) Contrat et support H24	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							
R008	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles	Serveur d'infrastructure (ESX, Oracle, ...)	manque de performance	Capacités mal évaluées	4	2	7	Gestion des capacités fournies par ZZZ	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							
R009	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles	Serveur d'infrastructure (ESX, Oracle, ...)	faillie OS	Virus	4	3	9	MAJ OS par ZZZ et protection périmétrique	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							
R010	YYY	Données de santé	Disponibilité	Les données de santé ne sont plus accessibles	Serveur d'infrastructure (ESX, Oracle, ...)	faillie OS	Malveillance (exploitation de la faille)	4	2	7	MAJ OS par Orange et protection périmétrique	4	1	4	Risque à surveiller	4. Accepter	Le risque est accepté							

1. Intégrer la sécurité au sein d'une organisation

f. Classification des informations

- La classification selon la confidentialité des informations aide à définir des mesures de protection appropriées pour chaque type d'information.

	Intitulé	Explication	Exemple	Risque
C1	Accès libre	Tout le monde peut y accéder	Informations publiées sur le site internet	Aucun
C2	Accès à l'organisation	Seul le personnel de l'organisation est autorisé à accéder à l'information	Nom, adresse des partenaires et fournisseurs de l'organisation	Atteinte à l'image, gêne passagère
C3	Diffusion limitée	Au sein de l'organisation, seul un groupe de personnes est autorisé comme les membres du même projet	Plan technique d'un nouveau laboratoire ; Listes der personnes admissibles avant publication officielle...	Situation à risques ; pertes financières acceptables
C4	Confidentiel	L'information est accessible à une liste très restreinte d'utilisateurs à titre individuel	Contenu des brevets déposés ; Recherche en cours ; N° de sécurité sociale et noms...	Pertes financières inacceptables, poursuites judiciaires

1. Intégrer la sécurité au sein d'une organisation

f. Classification des informations

- Sur la base des niveaux de confidentialité définis, les mesures suivantes peuvent être implémentées :
 - Une politique de gestion des informations est définie :
 - Création d'un modèle de document indiquant le niveau de confidentialité ;
 - Sensibilisation du personnel et des partenaires à cette politique.
 - Les informations de niveau « **Confidentiel** » doivent être :
 - envoyées par mail de manière chiffrée et le mot de passe communiqué par SMS aux destinataires ;
 - stockées localement dans des conteneurs chiffrés.
 - Les informations de niveau « **Diffusion limitée** » doivent être échangées au travers d'un système documentaire collaboratif ayant des accès nominatifs contrôlés, par exemple MS SharePoint.

1. Intégrer la sécurité au sein d'une organisation

g. Gestion des ressources humaines

- **Avant embauche :**
 - Sélection des candidats et interviews ;
 - Vérification du CV (contacter les anciens employeurs, vérifier les diplômes, certifications...) du candidat ;
 - En fonction de la sensibilité du poste, un extrait de casier judiciaire peut être demandé.
- **Pendant l'embauche :**
 - Fourniture des accès logiques (création de comptes utilisateurs, accès aux répertoires nécessaires...) et physiques (badges) adaptés à la fonction ;
 - Sensibilisation aux politiques et procédures internes de l'organisation ;
 - Sensibilisation régulière à la sécurité adaptée aux fonctions ;
 - Processus disciplinaire en cas de non respect.
- **Au terme du contrat de travail :**
 - Retrait des accès et restitution du matériel fourni (badge, ordinateur, ...).

1. Intégrer la sécurité au sein d'une organisation

Conclusion

- Une politique de sécurité doit être adaptée à l'organisme et à ses évolutions ;
- la sécurité ne s'improvise pas et nécessite des professionnels ;
- les normes sont une aide pour mettre en œuvre une démarche d'amélioration continue de la sécurité ;
- les normes par nature ne délivrent pas un niveau de sécurité ;
- les normes ne prennent pas en compte toute la sécurité des systèmes d'information.

2. Intégrer la sécurité dans les projets

- a) Préambule
- b) Sécurité dans l'ensemble du cycle de vie d'un projet
- c) Sécurité prise en compte en fin de développement
- d) Approche par l'analyse et le traitement du risque
- e) Plan d'action SSI

2. Intégrer la sécurité dans les projets

a. Préambule

- Il s'agit de bien distinguer :
 - **la sécurité du système d'information** qui est un des objets du projet ;
 - **et la sécurité du projet en lui-même** (diffusion et traitement des informations).
- Concernant la sécurité du SI en lui-même :
 - toute activité étant gérée en mode projet, une bonne intégration de la sécurité dans l'organisation nécessite l'intégration de la sécurité dans chaque projet dans le respect de la réglementation ;
 - isoler les traitements de données sensibles au sein de projet pour avoir une meilleure maîtrise des risques et des mesures de sécurité à mettre en œuvre pour réduire ces risques.

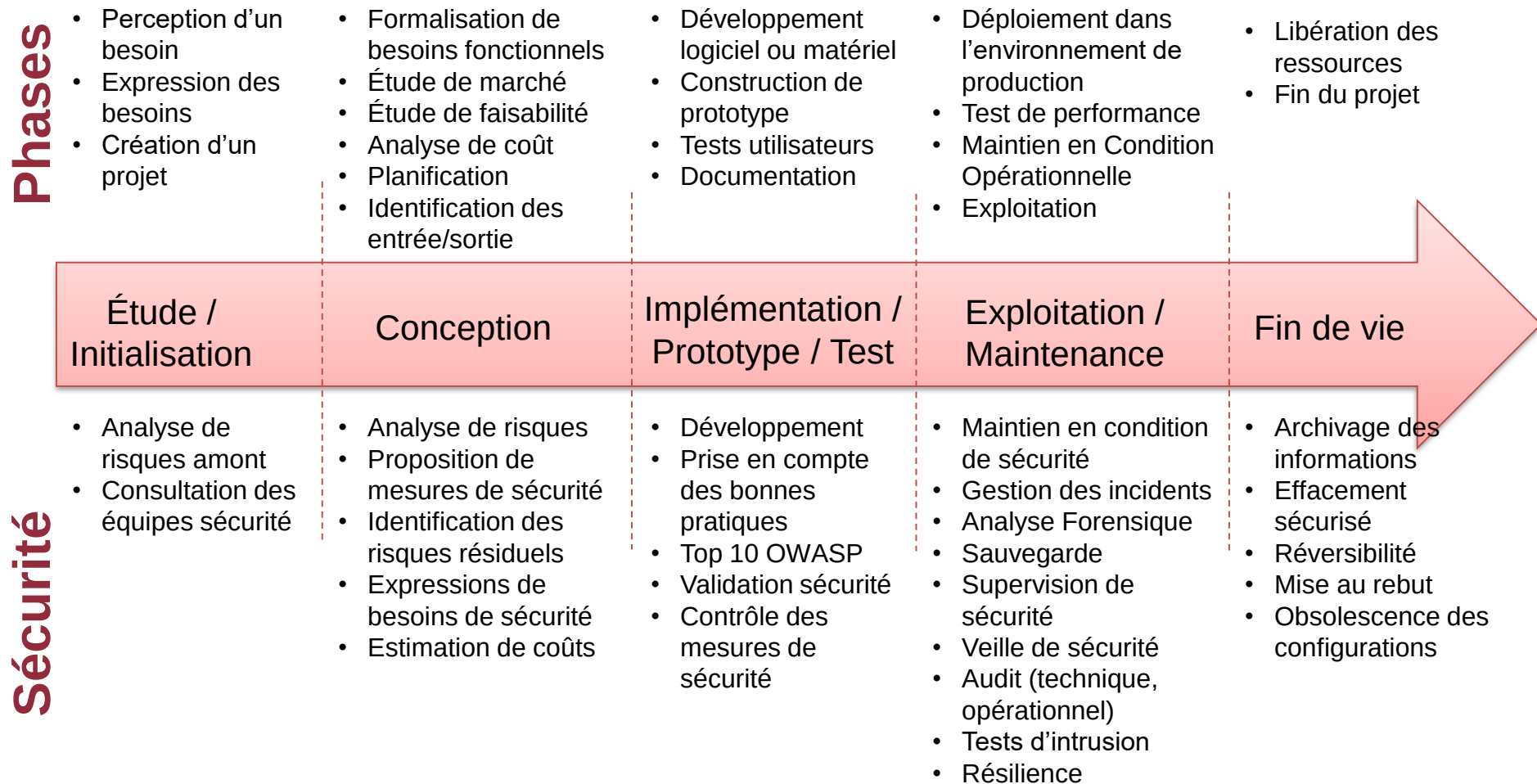
2. Intégrer la sécurité dans les projets

a. Preamble

- La sécurité doit être prise en compte dans toutes les étapes d'un projet :
 - Application de la démarche d'amélioration continue ;
 - Respect des impératifs et des contraintes notamment juridiques et réglementaires ;
 - Responsabilisation des acteurs, documentations, gestion du temps.

2. Intégrer la sécurité dans les projets

b. Exemple d'intégration de la sécurité dans le cycle de vie d'un projet



2. Intégrer la sécurité dans les projets

c. Sécurité prise en compte en fin de développement

- Exemple d'un projet de développement de site Web :
 - L'audit de sécurité fait le constat que :
 - Les versions de composants logiciels utilisés sont obsolètes et vulnérables ;
 - La base de données n'a pas été correctement isolée, et les tables ont été créées à l'intérieur d'une autre base de données à accès public ;
 - La politique de gestion de mots de passe n'est pas conforme aux bonnes pratiques : création de mots de passe faibles ; stockage de mots de passe en clair...
 - Le niveau de disponibilité attendu pour ce site ne peut être assuré avec l'infrastructure existante.
 - Conséquences :
 - Besoin de rachats de licences logicielles : coût supplémentaire ;
 - Recréation de la base de données sur un espace dédié correctement protégé ;
 - Redéveloppement des modules de gestion des mots de passe : coût supplémentaire ;
 - Modification de l'infrastructure pour assurer le niveau de disponibilité requis.

Délai, coût et effort supplémentaires...

2. Intégrer la sécurité dans les projets

c. Sécurité prise en compte en fin de déploiement

- Exemple d'un projet de construction d'une nouvelle salle devant héberger les serveurs de l'organisation :
 - L'audit de sécurité fait le constat que :
 - Les baies de stockage des serveurs ne se ferment pas à clé ;
 - Pas de mécanisme de contrôle d'accès (lecteur de badge) prévu tracer les accès ;
 - Pas de redondance (alimentation, accès de télécommunications) des équipements ;
 - Aucune alarme anti-intrusion ou incendie n'est prévue ;
 - L'arrivée de câbles dans la salle est exposée à des actes de malveillances ;
 - La salle est construite en zone inondable.
 - Conséquences :
 - Rachat de matériel et d'équipements => coût supplémentaire ;
 - Re-câblage de la salle, et travaux de génie civil à prévoir ;
 - Relocation de la salle ou reconstruction => coût supplémentaire très importante.

Reconstruction de la salle ou relocation de la salle, délai et coût supplémentaires...

2. Intégrer la sécurité dans les projets

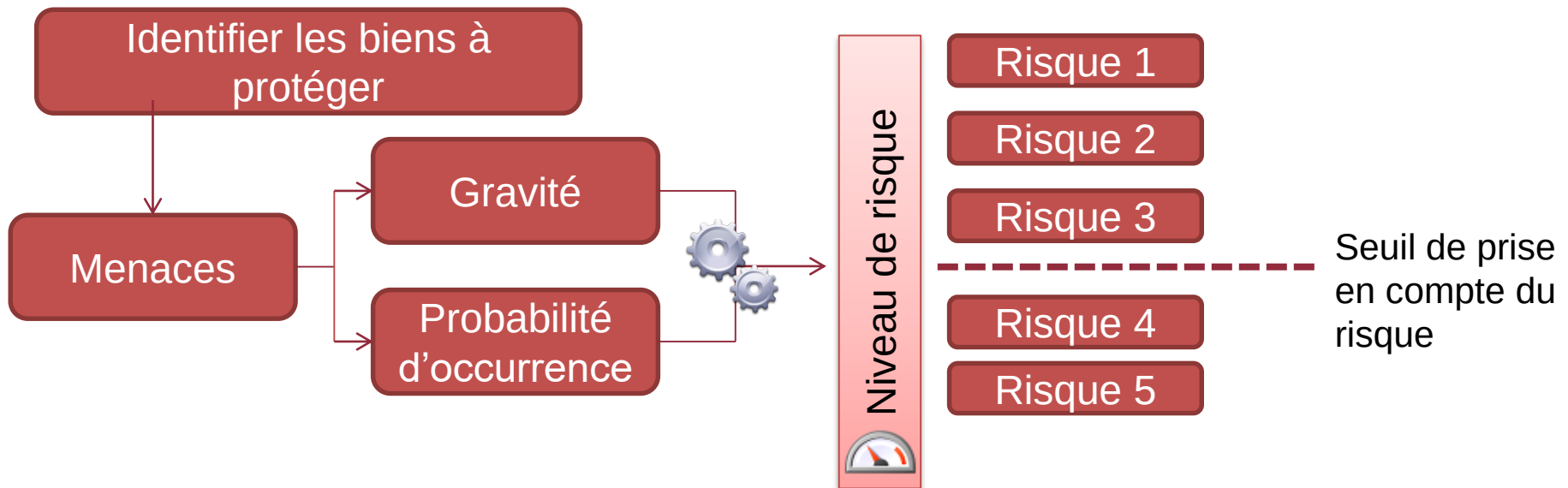
d. L'approche par l'analyse et le traitement du risque

- L'analyse de risques doit être effectuée en amont du projet mais doit aussi évoluer au fur et à mesure de l'exploitation du système (analyse de risque dynamique dans la supervision du système (SOC)) et fonction de l'évolution des risques (évolution des vulnérabilités, des menaces, du système d'information).
- L'analyse de risque consiste à :
 - identifier les biens à protéger,
 - analyser de la fréquence et la gravité du danger pour évaluer la criticité du risque,
 - établir une hiérarchisation des risques : fréquence vs gravité,
 - établir un seuil d'acceptabilité pour chacun de ces risques,
 - seuil au-delà duquel le risque doit être pris en compte par les mesures de sécurité.
 - identifier des mesures de sécurité.
- Les mesures ainsi identifiées peuvent constituer un cahier de charges sécurité pour le projet qui soit réalisé en interne ou externalisé.

2. Intégrer la sécurité dans les projets

d. L'approche par l'analyse et le traitement du risque

Une démarche d'analyse de risque peut être schématisée ci-dessous :



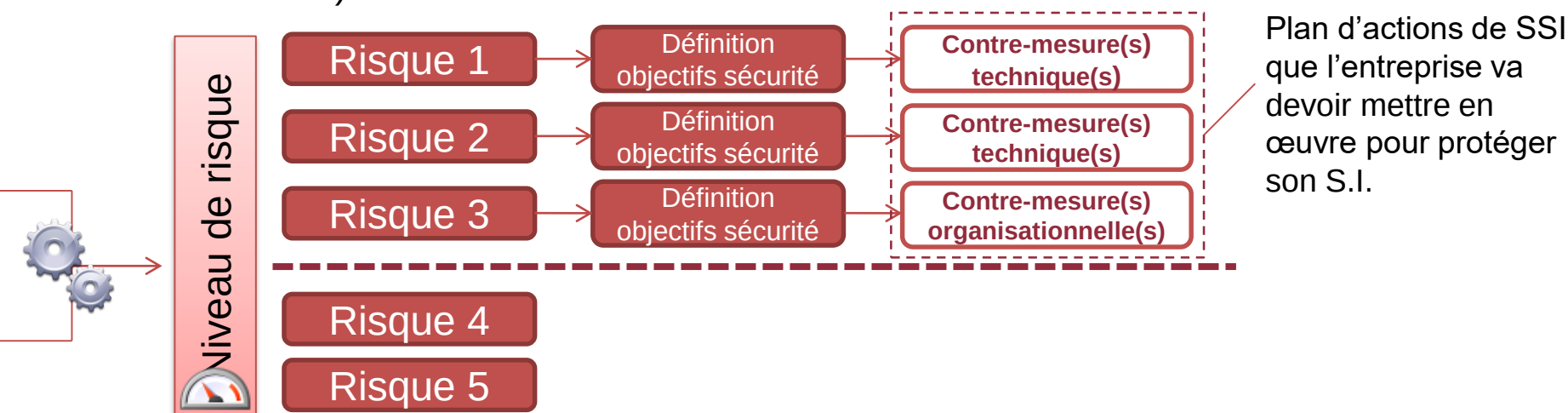
La hiérarchisation des risques permet de déterminer les risques qui :

- doivent absolument être traités et donc réduits par des mesures ;
- ceux qui sont acceptables et avec lesquels le système peut exister.

2. Intégrer la sécurité dans les projets

d. L'approche par l'analyse et le traitement du risque

- Pour les risques dont le niveau est supérieur au seuil de prise en compte :
 - Définir les objectifs de sécurité ;
 - Définir les mesures techniques et organisationnelles qui vont permettre d'atteindre ces objectifs.
- Pour les risques dont le niveau est inférieur au seuil de prise en compte :
 - **un risque résiduel** est le risque subsistant après le traitement de risque (car – par exemple – le coût pour compenser ce risque est trop élevé par rapport au risque encouru).



2. Intégrer la sécurité dans les projets

d. L'approche par l'analyse et le traitement du risque

Une analyse de risque peut être assez complexe et nécessite rigueur et méthode, il faut notamment trouver le bon niveau abstraction.

Voici 3 exemples de méthodes d'analyses de risque compatibles avec les lignes directrices de l'ISO 27005 :

- **EBIOS** : Expression des Besoins et Identification des Objectifs de Sécurité
développée par le Club EBIOS auquel participe l'ANSSI, l'Agence nationale de la sécurité des systèmes d'information
- **MEHARI** : MEthode Harmonisée d'Analyse de Risques
développée par le CLUSIF, Club de la Sécurité de l'Information Français
- **OCTAVE** : Operationally Critical Threat, Asset, and Vulnerability Evaluation
développée par l'Université de Carnegie Mellon.

2. Intégrer la sécurité dans les projets

e. Plan d'actions SSI

Le défi vis-à-vis de la mise en place des mesures de sécurité est **asymétrique** entre « attaquer » et « défendre » :

- L'attaque peut réussir par l'exploitation d'une seule vulnérabilité ;
- Tandis que la défense doit prendre en compte l'ensemble du système.

Un plan d'action des mesures de sécurité à mettre en place à l'issue de l'analyse de risques devrait respecter le principe de « **défense en profondeur** » qui recommande :

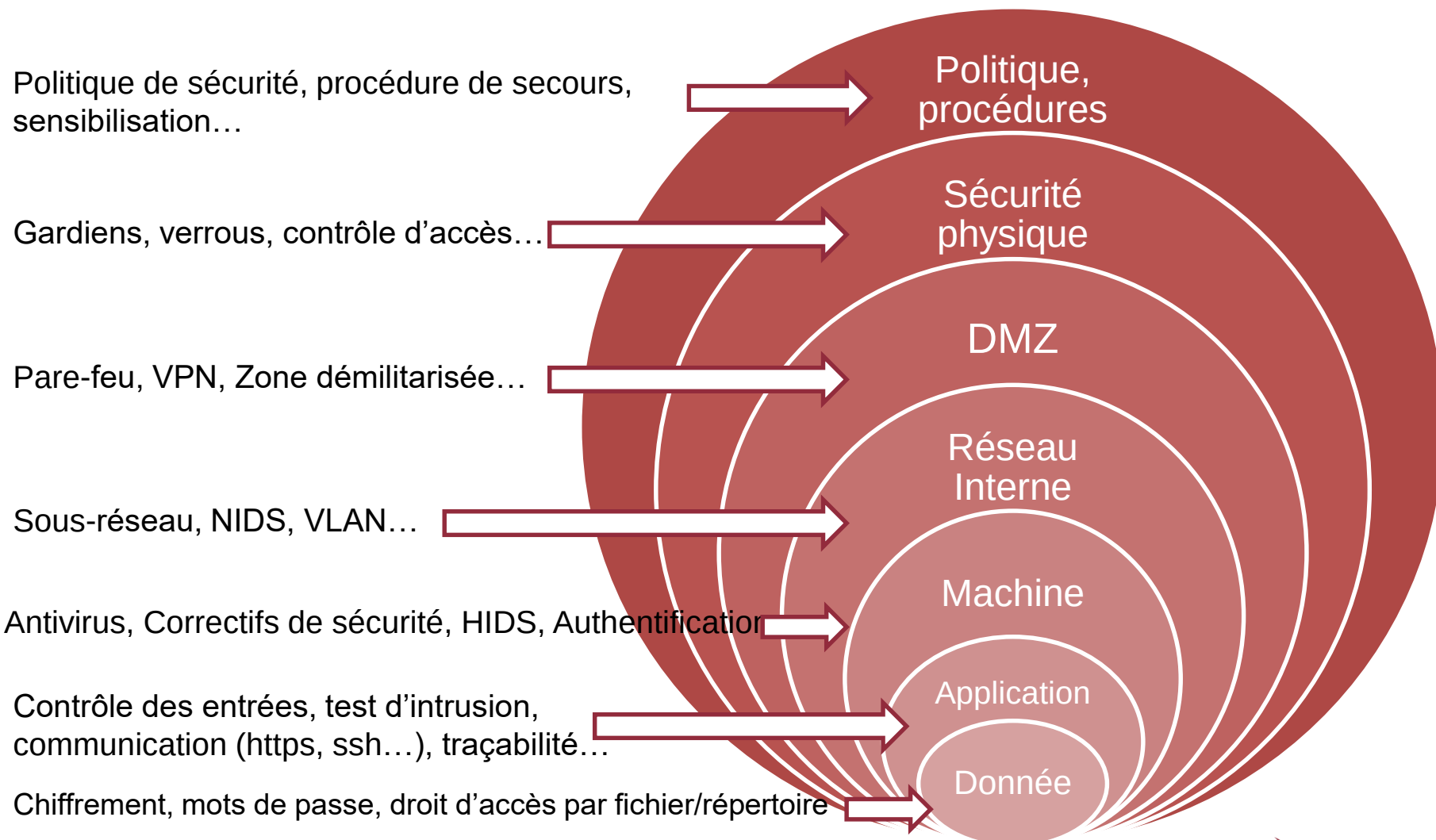
- d'avoir plusieurs lignes de défenses indépendantes ;
- que chaque ligne constitue une barrière autonome contre les attaques ;
- que la perte d'une ligne de défense implique qu'on passe à un niveau de défense plus fort.

Les objectifs de la défense en profondeur sont :

- prévenir, bloquer, limiter, détecter, alerter, réagir, réparer.

2. Intégrer la sécurité dans les projets

e. Plan d'actions SSI



2. Intégrer la sécurité dans les projets

Conclusion

- La sécurité des systèmes d'information : un élément indispensable d'un projet ;
- une sécurité globale et cohérente, et non une accumulation de mesures et de produits de sécurité ;
- une politique de sécurité réaliste et pragmatique ;
- un élément clé : la connaissance du système d'information (cartographie) et de son niveau de sécurité (contrôle, audit) ;
- une difficulté et une nécessité : le maintien en condition de sécurité du système d'information ;
- un accroissement des besoins de sécurité : besoin en compétences et en professionnels.

3. Difficultés liées à la prise en compte de la sécurité

- a) Compréhension insuffisante des enjeux
- b) Implication nécessaire de la direction
- c) Difficulté pour faire des choix en toute confiance
- d) Délicat arbitrage entre commodité et sécurité
- e) Suivre l'évolution des technologies
- f) Frontières floues entre sphères professionnelle, publique, et privée

3. Difficultés liées à la prise en compte de la sécurité

a. Une compréhension insuffisante des enjeux...

...liée à un problème d'éducation

- L'information a une valeur importante pour l'entreprise, pour les concurrents, pour les États. On parle aujourd'hui de « guerre de l'information ».
 - Chaque année des centaines de compagnies en France sont victimes d'espionnage industriel ou économique :
 - Écoute des conversations ;
 - Espionnage des écrans d'ordinateurs ;
 - Social engineering, etc.
 - Des actes aisés dans les transports : train, avion, etc.



Les voyageurs aux USA perdent environ
12 000 pc portables chaque semaine*

*source : Ponemon Institute

3. Difficultés liées à la prise en compte de la sécurité

a. Une compréhension insuffisante des enjeux

...liée à un problème de formation

- Des dirigeants qui n'ont pas tous une culture sécurité ;
- Des évolutions vers le poste de « RSSI », sans formation complémentaire adéquate :
 - personnel issu de la technique : administrateur réseau, système...
 - personnel issu de la qualité : responsable qualité... ;
- Un coût lié à la sécurité qui rebute en période de crise :
 - Authentification forte : achats de jetons/carte à puce ;
 - Plan de secours : acheter en double certains équipements ;
 - Personnel : former aux bonnes pratiques en sécurité...

3. Difficultés liées à la prise en compte de la sécurité

a. Une compréhension insuffisante des enjeux...

...entraînant de nombreux risques pour l'entreprise ou pour l'organisation

- Perte d'informations essentielles ;
- Arrêt de la production ;
- Détérioration de l'image/réputation ;
- Risques juridiques/réglementaires...

...entraînant de nombreux risques pour les États

- Indisponibilité de services ;
- Perte de crédibilité ;
- Divulgation d'informations sensibles ;
- Risques de conflits avec d'autres États...

3. Difficultés liées à la prise en compte de la sécurité

b. L'implication nécessaire de la direction

Rien ne peut se faire sans l'aval de l'exécutif.

Le chef d'entreprise doit être conscient des enjeux de sécurité pour l'avenir de son entreprise :

- Être **proactif** plutôt que réactif. La PSSI est une réflexion stratégique : Elle permet de prévoir l'avenir de l'organisation ;
- **Prendre le temps** de comprendre, ne pas être absorbé que par ses marchés, ses clients, ses concurrents, son relationnel ;
- La sécurité :
 - **va au-delà de la technique**. L'humain joue un rôle central ;
 - **ne doit pas rester un domaine d'experts**. La sécurité est l'affaire de tous et une préoccupation de tous les responsables ;
 - n'est pas seulement une contrainte coûteuse mais **elle est aussi un investissement**, un atout supplémentaire pour l'organisation.

3. Difficultés liées à la prise en compte de la sécurité

b. L'implication nécessaire de la direction

Investir dans la sécurité ne suffit pas. Il faut être conscient des enjeux vis-à-vis de l'organisation. La dynamique sécurité viendra de la direction.

- Le dirigeant doit **montrer l'exemple** d'abord en y accordant un intérêt : charismatique, il est le premier à sensibiliser les personnes concernées ;
- **Motiver** son RSSI ou ses administrateurs pour faire appliquer la politique de sécurité de l'organisation et maîtriser leurs systèmes le mieux possible ;
- **Responsabiliser** : en désignant un responsable de la coordination, qui distribuera les tâches au sein des équipes ;
- **Réagir** en cas d'attaque avérée : mettre des ressources à disposition, permettre l'expertise juridique et porter plainte ;
- **Impliquer** ses personnels, les sensibiliser et leur permettre de suivre des formations.

3. Difficultés liées à la prise en compte de la sécurité

c. Difficulté pour faire des choix en toute confiance

Il est important de faire des choix éclairés en prenant en compte la sécurité.

"L'implantation en France des chinois Huawei et ZTE pose une question de sécurité nationale"



Par **JMBockel** (Express Yourself) publié le 01/10/2012 à 15:12, mis à jour à 15:25



Vie privée : La NSA s'octroie un backdoor dans tous les systèmes Windows



Le Gouvernement Chinois a adopté une nouvelle réglementation exigeant aux entreprises qui vendent des ordinateurs aux banques chinoises de fournir le code source et de se soumettre à des audits.

3. Difficultés liées à la prise en compte de la sécurité

c. Difficulté pour faire des choix en toute confiance

Quels sont aujourd'hui les matériels ou logiciels de confiance ?

- Ceux issus de l'industrie nationale vs ceux de nos partenaires de confiance : alliés, fournisseurs ;
- Ceux issus du monde libre (« open source ») ;
- Les matériels qualifiés par l'ANSSI.

Quels sont les organismes de confiance ?

- Les entreprises nationales ou européennes (mais qui sont les actionnaires) ;
- Nos partenaires de longue date ;
- Les autorités gouvernementales ;
- Les prestataires de service qualifiés par l'ANSSI.

3. Difficultés liées à la prise en compte de la sécurité

d. Le délicat équilibre entre productivité et sécurité : contexte

- Authentification requise pour chaque application dans l'entreprise
 - Problème pour l'utilisateur : « J'ai besoin de travailler chaque jour avec 5 applications et je dois à chaque fois y saisir un mot de passe différent ».
 - Réaction pour l'utilisateur : « Je note certains mots de passe sur papier ».
- Utiliser une application de chiffrement pour partager les fichiers chiffrés avec des partenaires
 - Problème pour l'utilisateur : l'interface de Crypt&Share n'est pas ergonomique.
 - Réaction de l'utilisateur : « Je vais utiliser Box ou DropBox pour partager les informations avec mes partenaires ».
- Les informations classifiées au niveau 4 (niveau de sensibilité le plus élevé) ne doivent pas sortir du S.I.
 - Problème pour l'utilisateur : J'ai besoin de l'avis d'un prestataire extérieur sur certaines informations de niveau 4.
 - Réaction de l'utilisateur : Déclassification des informations de manière à ne jamais avoir de niveau 4 mais uniquement des niveaux 3 ou 2.

3. Difficultés liées à la prise en compte de la sécurité

d. Le délicat équilibre entre productivité et sécurité

- Les usages fondent les pratiques... entre ce qui est acceptable à l'utilisateur, ce qui est nécessaire au bon fonctionnement de l'organisme et ses besoins de sécurité.

D'où l'importance :

- De la **pédagogie** : expliquer à quoi servent les procédures, leurs bienfondés, leur intérêt pour l'organisation ;
- De **l'implication des dirigeants** : qui viendront renforcer ces convictions ;
- De la prise en **compte des remarques et éventuelles oppositions des utilisateurs** : ergonomie, pratique, simplicité de mise en œuvre etc. ;
- La mise en place d'une **charte informatique** signée et connue de tous ;
- De **régulièrement rappeler les règles** : changer les mots de passe, rejouer les procédures, créer une check-list etc. ;
- De sensibiliser en évoquant les incidents réels qui se produisent et peuvent se produire dans l'organisation.

3. Difficultés liées à la prise en compte de la sécurité

d. Le délicat équilibre entre productivité et sécurité

- **Écouter les utilisateurs** et prendre en compte leurs besoins lors de l'étude de solutions de sécurité :
 - Proposer des mesures en concertation et avec l'adhésion des utilisateurs concernés autant que possible ;
 - **Former les utilisateurs** pour les aider à prendre en main les nouveaux outils et à bien appliquer les mesures.
- **Tester les procédures**, dans le but d'évaluer son efficacité (applicabilité, réalisation des objectifs, risques encourues) :
 - Éviter de multiplier les moyens de protection si ceux-ci ne sont pas respectés ;
 - il faut parfois investir moins dans la sécurité mais avoir des procédures efficaces.
- **Confier la responsabilité de la sécurité à un collaborateur** qui a le pouvoir ou les ressources pour la faire appliquer.
- Choisir les solutions les plus adaptées à **sa propre structure**, à **son** fonctionnement, au niveau de maturité l'entreprise.

3. Difficultés liées à la prise en compte de la sécurité

e. Suivre l'évolution des technologies : le Cloud

- Les technologies Cloud se popularisent de plus en plus au sein des entreprises. Les raisons évoquées sont diverses et peuvent être :
 - Réduction des coûts
 - Meilleure accessibilité
 - gestion confiée à un tiers
- Mais les mesures de sécurité et réglementaires constituent toutefois des « freins ».
- Le **SaaS** (Software as a Service) est l'usage du Cloud le plus rencontré en entreprise :
 - SaaS est la fourniture d'applications sous forme de service à la carte. L'application est installée dans le Cloud (Datacenter) et l'utilisateur paye une licence d'utilisation.
- Les utilisateurs finaux souscrivent aujourd'hui à des services SaaS sans l'aval de la direction informatique et en dépit des règles de sécurité. Ils accèdent au SaaS à travers divers terminaux souvent non contrôlés par l'entreprise. On parle alors de « **Shadow IT** » :
 - Dans une entreprise du CAC, le DSI estimait à près de 100 le nombre total d'applications. Un audit de découverte du Cloud a révélé près de 2500 usages SaaS.

3. Difficultés liées à la prise en compte de la sécurité

e. Suivre l'évolution des technologies : le Cloud

Le recours à des services type Cloud pose de nouvelles problématiques que l'entreprise se doit de résoudre, notamment :

- Le choix d'un fournisseur
 - Est-ce que le fournisseur dispose de certification relatives à l'hébergement (Exemple : SAS 70 II)?
 - Est-ce que le fournisseur est agréé par une autorité nationale?
- Le stockage
 - A qui appartiennent **légalement** les données lorsqu'elles sont hébergées ?
 - Quelles sont les mesures de protection des données stockées?
 - Les systèmes sont-ils mutualisés avec d'autres clients ou nous sont-ils dédiés ?
 - Qui doit fournir les clés cryptographiques ?
 - Comment les données sont-elles sauvegardées, redondées ?
- Le transport des données
 - Qui fournit l'infrastructure de transport?
 - quels sont les mécanismes de sécurité en place?
- Fin de contrat : réversibilité
 - Que deviennent les données lorsque le contrat expire ? Comment sont-elles restituées au client, supprimées du Cloud et qu'advient-il des données sauvegardées sur bande ?

3. Difficultés liées à la prise en compte de la sécurité

e. Suivre l'évolution des technologies : le Cloud

- Les guides suivants peuvent être utiles pour choisir un fournisseur SAAS :
 - **Guide Contractuel SAAS** : <http://www.syntec-numerique.fr/content/publication-du-guide-contractuel-saas>
 - **Recommandations CNIL pour la souscription au SAAS** : <http://www.cnil.fr/linstitution/actualite/article/article/cloud-computing-les-conseils-de-la-cnil-pour-les-entreprises-qui-utilisent-ces-nouveaux-services/>
 - **Guide de l'ANSSI** : « Sécurité de l'externalisation » : <http://www.ssi.gouv.fr/entreprise/bonnes-pratiques/externalisation/>
- Les Cloud Access Security Brokers (CASB) ou les Cloud Security Gateway (CSG) sont des composants logiciels ou matériels qui se situent entre les utilisateurs et le fournisseur SaaS et permettent :
 - de protéger les données des utilisateurs de l'entreprise de manière à ce que l'éditeur SaaS ne puisse les lire ;
 - de gérer les accès et de l'authentification unique (SSO) ;
 - de conserver les données en local via de la tokenisation ou de les chiffrer avant de les envoyer vers le fournisseurs SaaS...

3. Difficultés liées à la prise en compte de la sécurité

e. Suivre l'évolution des technologies : le Cloud

- Le Cloud pourrait à terme rendre les autres moyens de sauvegarde désuets :
 - sauvegarder une copie de son S.I. au sein du Cloud permettra à l'organisation de redémarrer une activité saine à tout moment en cas d'incident ;
 - A partir d'une sauvegarde, un espace de travail peut être accessible de n'importe quel endroit du monde pour tous ceux qui y sont autorisés.
- La fédération d'identité est un usage du Cloud qui peut permettre aux entreprises de mieux gérer les identités de ses utilisateurs et de :
 - centraliser les comptes utilisateurs ;
 - d'octroyer et de retirer facilement les droits d'accès sur plusieurs applications en interne ou en externe ;
 - tracer les utilisateurs et leurs actions...

3. Difficultés liées à la prise en compte de la sécurité

e. Suivre l'évolution des technologies : le Big Data

- « Big Data » recouvre l'exploitation des données massives impossibles à manipuler avec les outils classiques comme les bases de données.
 - Le « Big Data » comme outil de sécurité :
 - Modélisation des comportements et détection des anomalies sur la base de corrélation des données issues du trafic réseau ;
 - Détection possible des attaques persistantes avancées (APT) ;
 - Meilleure efficacité des outils tels que des SIEM, IDS, ou IPS ;
 - Surveillance du trafic réseau pour identifier des botnets.
 - Le « Big Data » représente un enjeu pour la sécurité des S.I. :
 - La source de données doit être fiable, et intègre (comme dans toute collecte d'information) ;
 - L'anonymisation des données manipulées représente une véritable difficulté compte tenu de leur volume important ;
 - La localisation des données car le « big data » est souvent exploité dans le « cloud » et les réglementations applicables ;
 - La protection de données exploitées est importante et le chiffrement peut être difficile à assurer. Un vol de données aura une ampleur beaucoup plus importante.

3. Difficultés liées à la prise en compte de la sécurité

f. Des frontières floues entre sphères professionnelle, publique, et privée

Quel est le périmètre de confiance ?

- Internet est un réseau mondial ouvert ; dans un monde concurrentiel, il est naturel qu'il soit **source de menaces** ;
- Les réseaux d'entreprises sont des **réseaux internes**, généralement protégés de façon périmétrique, mais peu protégés en interne...
- Les multinationales possèdent souvent de **grands réseaux ouverts à des exploitants**, des services de télémaintenance et des sous-traitants qui ont des d'accès conséquents sur ces réseaux, et qui possèdent eux-mêmes leurs propres informations ;
- De plus, de nombreux « nouveaux » **appareils sont utilisés** (smartphones, tablettes etc.) faiblement sécurisés et connectés directement à Internet (Wifi, 3G/4G, etc.) sans passer par les dispositifs de sécurité de l'entreprise ;
- Les données personnelles peuvent ainsi être présentes sur le réseau d'entreprise.

3. Difficultés liées à la prise en compte de la sécurité

f. Des frontières floues entre sphères professionnelle, publique, et privée

BYOD - Focus sur le smartphone personnel (ou la tablette personnelle) :

- Il nous accompagne au travail, lors de nos déplacements ;
 - On le connecte à notre PC de bureau pour le recharger en USB ;
 - Il remplace souvent notre téléphone professionnel, peut-être moins performant ou restreint en terme de fonctionnalités ;
 - Pour des raisons de facilité, on y configure notre messagerie professionnelle, nos contacts, notre emploi du temps... autant d'informations qui peuvent potentiellement être sensibles pour l'entreprise.
- La frontière entre nos informations privées et nos informations professionnelles devient donc **très floue** ;
 - Dès que les informations sont stockées sur un smartphone personnel, l'entreprise en perd la maîtrise (l'équipement ne lui appartient pas, elle ne peut pas imposer ses règles...).

3. Difficultés liées à la prise en compte de la sécurité

f. Des frontières floues entre sphères professionnelle, publique, et privée

Raconter, partager sa vie privée sur l'Internet c'est y être pour la postérité...

- **Nos données nous échappent dès l'instant où nous les publions** : Dans le meilleur des cas, on pourra effacer notre propre publication, mais on ne pourra pas effacer les multiples copies que l'on ne contrôle pas (droit à l'oubli illusoire par manque de maîtrise de l'information) ;
- C'est permettre à tout inconnu, **d'entrer dans notre sphère privée** ; la restriction des accès aux « amis » n'est qu'illusoire dans l'absolu ;
- c'est permettre aux Ressources Humaines de **filtrer notre CV** ; et déterminer le profil privé du candidat correspondant au profil professionnel recherché ;
- à nos collègues et supérieurs **d'interpréter nos propos...**

3. Difficultés liées à la prise en compte de la sécurité

f. Des frontières floues entre sphères professionnelle, publique, et privée

Partager les problèmes que l'on rencontre au travail : personnels, techniques, relationnels ; consulter des sites personnels au travail...

- c'est peut-être mettre en danger son organisation : en offrant à un pirate ou un concurrent des **informations précieuses** (version d'un logiciel, faille de sécurité, fournisseurs, secrets commerciaux, informations RH...) ;
- transgresser la **déontologie** du travail, ou la **charte de confidentialité** ;
- potentiellement s'exposer à des sanctions en interne qui peuvent aller jusqu'au pénal.

3. Difficultés liées à la prise en compte de la sécurité

Conclusion

- Évolution des modes, des besoins, des technologies, des habitudes ;
- au-delà des nouveautés, toujours le même problème : la non-prise en compte de la sécurité (développement, implémentation, exploitation, formation) ;
- un périmètre d'attaque et d'accident plus étendu mais peu nouveau ;
- une prise en compte permanente des enjeux et de la sécurité par tous (hygiène informatique) et par le chef d'entreprise ;
- un accroissement des besoins de sécurité : besoin en compétences et en professionnels.

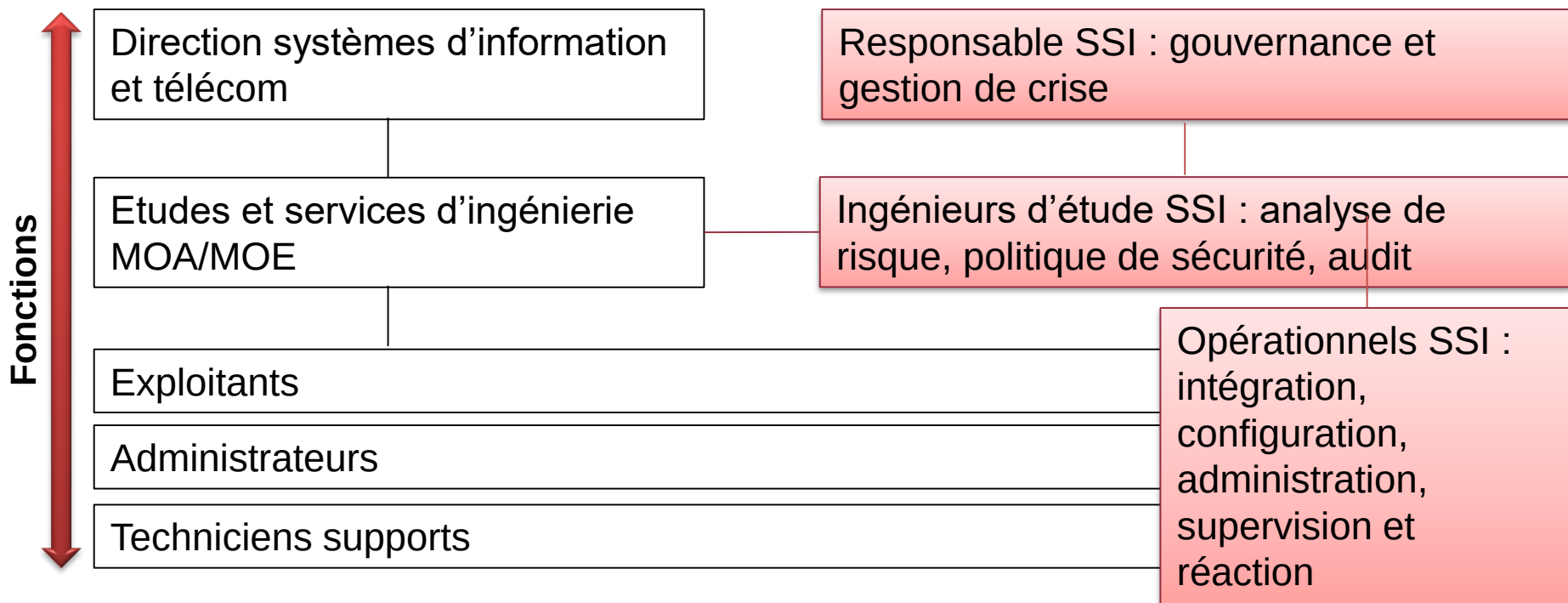
4. Les métiers en cybersécurité

- a) Positionnement des métiers au sein des organisations
- b) Cartographie des métiers et compétence
- c) Profils et carrières
- d) Perspectives d'embauche

4. Les métiers

a. Positionnement des métiers au sein des organisations

La cybersécurité est transverse à toute activité qui requiert de l'informatique et des réseaux de télécommunications, de la TPE à la multinationale, dans le domaine privé ou public.



4. Les métiers

a. Positionnement des métiers au sein des organisations

Selon la taille de l'organisation (PME/PMI/Grande entreprise...), les fonctions liées à la cybersécurité nécessitent une charge de travail qui varie. Il est possible d'avoir du personnel à temps partiel ou du personnel dédié à la sécurité.

Et cela sur l'ensemble des couches depuis la gouvernance jusqu'à l'opérationnel : par exemple.

ETP = Équivalent Temps Plein

DSI = Direction des Systèmes d'Information

SSI = Sécurité des Systèmes d'Information

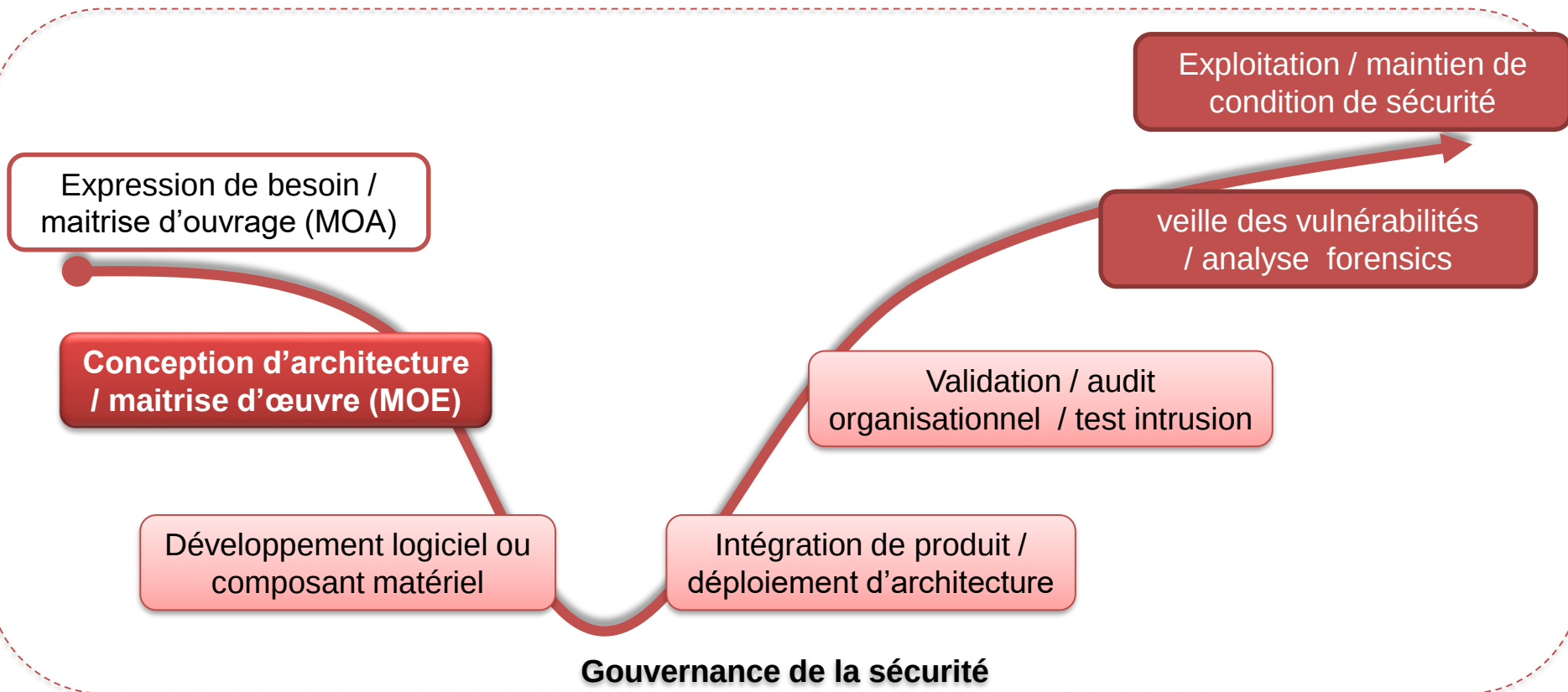
PSSI = Politique de Sécurité des Systèmes d'Information

	PME/PMI DSI 15 pers	Grande entreprise DSI 500 pers
Responsable SSI : gouvernance et gestion de crise	¼ ETP du Dir. du S.I.	3 à 5 ETP
Ingénieurs d'étude SSI : analyse de risque, mise en œuvre PSSI, audit...	¼ ETP des études S.I.	5 à 10 ETP
Opérationnels SSI : intégration, configuration, administration, supervision et réaction	1 ETP réparti sur l'exploitation du S.I.	20 à 50 ETP si H24 7/7

4. Les métiers

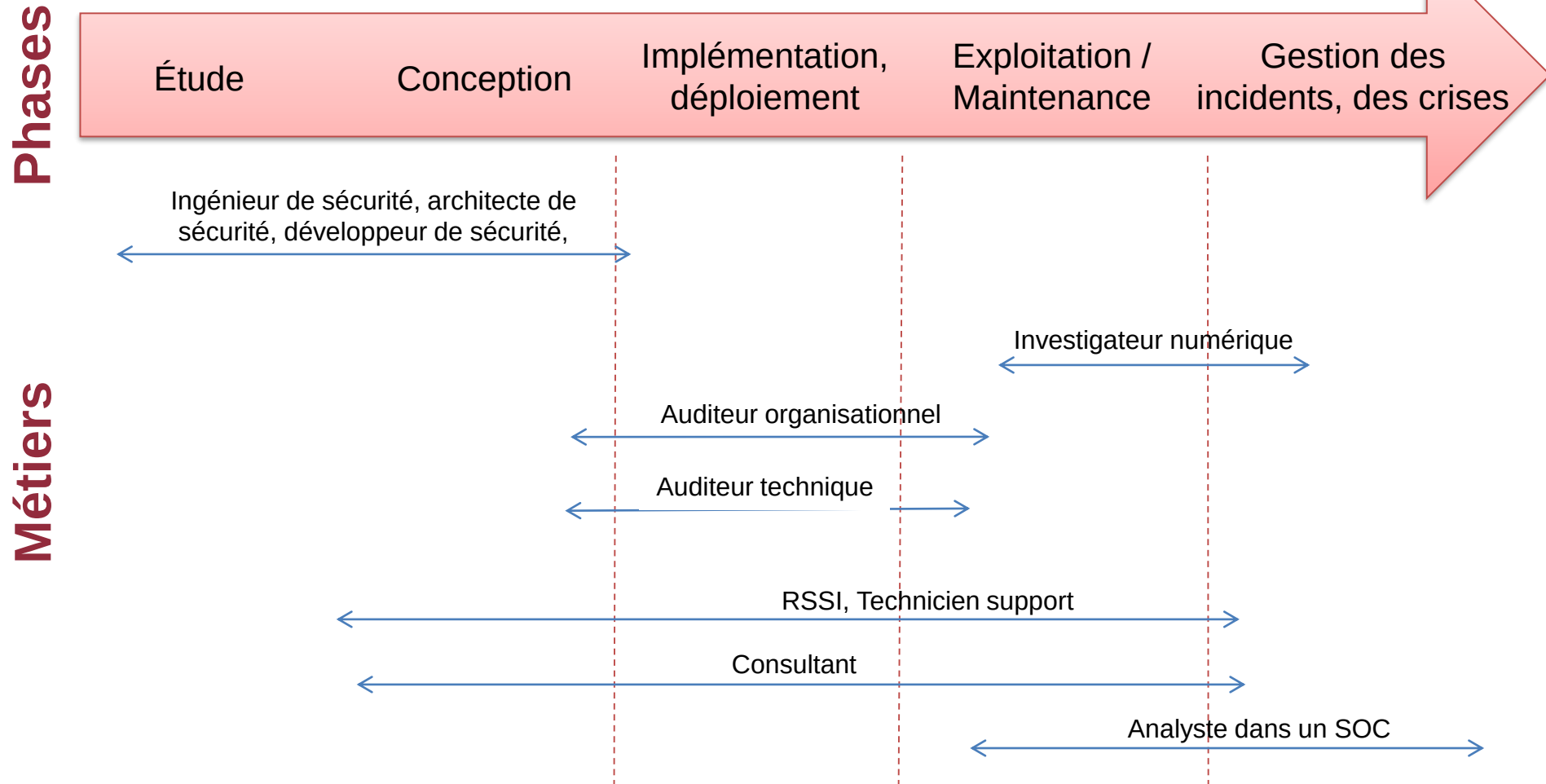
b. Cartographie des métiers et compétence en SSI

Les métiers se répartissent dans le cycle de vie d'un projet depuis l'expression de besoin jusqu'au retrait de l'exploitation sous la responsabilité de la gouvernance globale de l'organisation.



2. Intégrer la sécurité dans les projets

b. Cartographie des métiers et compétence en SSI



4. Les métiers

b. Cartographie des métiers et compétence en SSI

Les métiers se répartissent dans les familles de l'informatique et des réseaux.

	Nb année expérience	Compétence technique	Compétence management
Gouvernance des systèmes d'information			
•Responsable ou Directeur	15 à 20	X	XXX
•Chef de projet / Consultant MOA	5 à 15	XX	XX
Conception et déploiement de système d'information			
•Chef de projet / Consultant MOE	5 à 15	XX	XX
•Architecte système	10 à 15	XXX	
Développement logiciel et matériel			
•Architecte/concepteur logiciel/composant	5 à 10	XXX	
•Développeur logiciel (dont cryptologue)	0 à 10	XXX	
Exploitation			
•Technicien système et réseau	0 à 10	XXX	
•Administrateur système et réseau	0 à 10	XXX	X
•Analyste veille/gestion des incidents/forensics	0 à 10	XXX	X
Validation / Audit			
•Auditeur technique SSI (dont test intrusion)	0 à 10	XXX	X
•Auditeur organisationnel SSI	5 à 10	X	X

Compétence
requis :
X : peu de
compétence
XX : niveau
moyen
XXX : forte
compétence

4. Les métiers

c. Profils et carrières

- **Responsable de la Sécurité des Systèmes d'Information (RSSI)** : définit la politique de sécurité du SI et veille à son application ; il assure un rôle de conseil, d'assistance, d'information, de formation et d'alerte.
- **Architecte [système, logiciel] sécurité** : l'architecte sécurité structure les choix techniques, technologiques et méthodologiques d'un ensemble [système, logiciel] répondant à des exigences de sécurité.
- **Développeur [produit, logiciel] de sécurité** : le développeur de sécurité assure le sous-ensemble des activités d'ingénierie nécessaires à la réalisation d'éléments [produit, logiciels] répondant à des exigences de sécurité.

4. Les métiers

c. Profils et carrières

- **Technicien ou Administrateur système et réseau** : assure ou est responsable de diverses activités de support, de gestion ou d'administration de la sécurité aux plans techniques ou organisationnel.
- **Analyste** : assure la veille sur les vulnérabilités des produits et logiciel, , recherche et détecte les incidents de sécurité coordonne le suivi de l'application des correctifs.
- **Auditeur Organisationnel** : contrôle la prise en compte de la sécurité au niveau organisationnel sur la gouvernance, les procédures de sécurité notamment vis-à-vis de la norme ISO27K. Il vérifie la conformité des mesures mises en œuvre.
- **Auditeur Technique** : contrôle les configurations des équipements et logiciels. Il est en mesure de pénétrer les défenses d'un système d'information et d'identifier les divers chemins d'intrusions possibles et leurs conséquences. Il vérifie l'efficacité des mesures en place pour protéger le système.

4. Les métiers

c. Profils et carrières

La majeure partie des postes SSI sont occupés actuellement par des personnes ayant une formation informatique ou télécom, s'étant spécialisées au cours de leur carrière par des formations / certifications.

Certaines certifications en SSI peuvent être effectuées en 5 jours et se terminer par un examen comme par exemple :

- | | | |
|---|---|--|
| <ul style="list-style-type: none">• ISO 27001 Lead Auditor• ISO 27001 Lead Implementor• ISO 27005 Risk Manager | } | Compétence Technique : X
Compétence Management : XXX |
| <ul style="list-style-type: none">• CISSP : Certified Information System Security Professional• CEH : Certified Ethical Hacker | } | Compétence Technique : XX
Compétence Management : XXX |
| | } | Compétence Technique : XXX
Compétence Management : X |

On note depuis une dizaine d'années, un accroissement des formations spécialisées en sécurité de niveau bac+4/5. Elles permettent généralement de démarrer une carrière sur des postes qui requièrent des compétences techniques.

Possibilité de progression de carrière depuis la production technique jusqu'à de la direction/management en passant par de la vente ou du marketing de produits/services.

4. Les métiers

d. Perspectives d'embauche

- Métiers avec une forte demande annoncée pour les 15 prochaines années :
 - progression de la virtualisation de IT et des réseaux,
 - révolution digitale des services aux usagers (BToC) et entre entreprise (BtoB),
 - Internet des objets...
- Dans tous les secteurs privés banque, industrie, commerce...
- Ainsi que dans le secteur public : administration, collectivité territoriale, hôpitaux, universités...
- Mais surtout au sein de sociétés de service, principaux employeurs de diplômés depuis 20 ans pour intervenir en sous-traitance ou assistance technique pour les entreprises et les administrations :
 - les organisations tendent à se concentrer sur leur métier et faire de la délégation de service pour les fonctions supports dont la sécurité.

4. Les métiers

d. Perspectives d'embauche

- Exemples d'organisations spécialisées dans la cybersécurité et qui recrutent :
 - Éditeurs/Constructeurs de produit de sécurité (anti-virus, boîtier de chiffrement, pare-feu, ICG...) : développement, marketing et vente ;
 - Tiers de confiance qui exploite des infrastructures pour des clients (produits/services de sécurité en mode IaaS, SaaS) : conception et déploiement, exploitation, marketing et vente ;
 - Sociétés de service/cabinet de conseil : conseil, expertise, audit... ;
 - Organismes étatiques comme l'ANSSI, ministère de la défense (DGSE, Armées), ministère de l'intérieur (DGSI, police judiciaire, gendarmerie nationale), la CNIL : conseil, expertise, audit... ;
 - Entreprises proposant ou gérant des SOC.



CyberEdu

La sécurité par l'enseignement supérieur des NTIC

Merci de votre attention

Ce document pédagogique a été rédigé par un consortium regroupant des enseignants-chercheurs et des professionnels du secteur de la cybersécurité.



Il est mis à disposition par l'ANSSI sous licence Creative Commons Attribution 3.0 France.



CyberEdu
La sécurité par l'enseignement supérieur des NTIC